ANSWERKEY

B.Tech. V SEM R24 MID I EXAMINATIONS

24CSPC52– INFORMATION AND CYBER SECURITY

1

a. Whatis CIATriad?

CIATriadisthefoundationalsecuritymodelcomprisingthreecoreprinciples:

- Confidentiality:Ensuringdataisaccessibleonlytoauthorizedusers;preventsunauthorizeddisclosure.
- Integrity:Guaranteeingdataaccuracyandcompleteness;preventsunauthorizedmodificationordeletion.
- Availability: Ensuring systems/data are accessible to authorized users when needed; prevents denial of service. These three pillars form the basis of information security policy and risk management frameworks.

b. DefineNIA.

NIA: Network Information Assurance (NIA) is a security framework that sets rules to protect digital data and stop cyber attacks..

c. Defineencryptionanddecryption.

Encryption:Processofconvertingplaintext(readabledata)intociphertext(unreadablecodedform)usingan algorithm and a key, making data uninterpretable to unauthorized parties.

Decryption:Reverseprocessofconvertingciphertextbackintoplaintextusingthecorrespondingkeyand algorithm, restoring the original readable data.

d. ListthefourprincipalcomponentsinOpenSSL.

FourprincipalcomponentsofOpenSSL:

1. SSL/TLSLibrary—Protocolimplementationforsecurecommunicationandencryption.
2. CryptographicLibrary—Algorithmsforsymmetric/asymmetricencryption,hashing,anddigitalsignatures.
3. Command-line Tools — Utilities for key generation, certificate management, and encryption/decryption operations.
4. X.509 Certificate Handling — Public key infrastructure (PKI) support for certificate validation and management.

e. Listoutfewofthepopularcybercrimes.

Popularcybercrimes:

Phishing: Fraudulent emails/messages posing as legitimate sources to steal credentials Ransomware: Malware encrypting data and demanding payment for decryption Identity theft: Unauthorized use of personal information for fraud

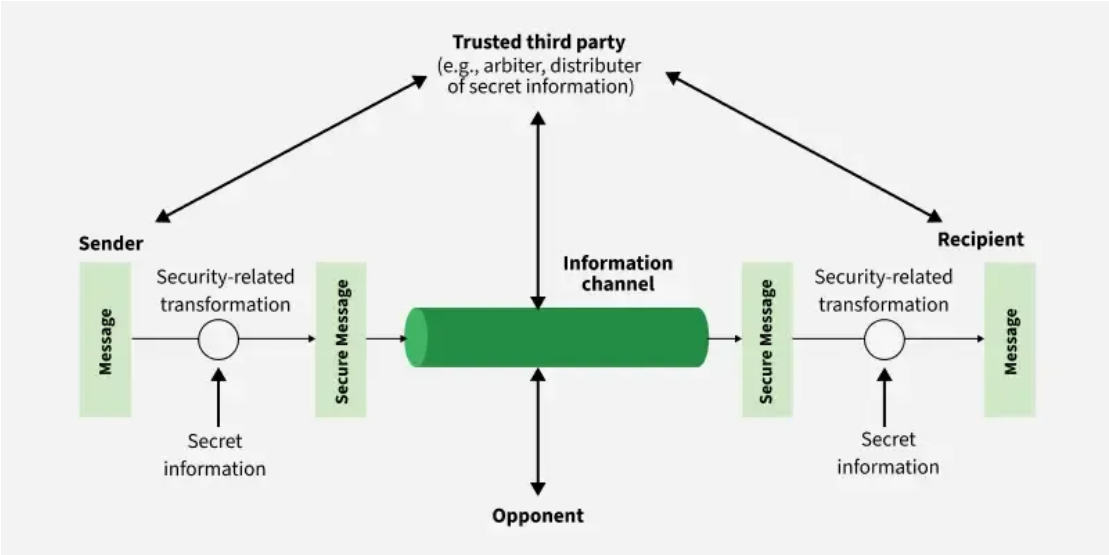
Malware/Viruses:Maliciousoftwaredesignedtodamageorexploitsystems

DDoS attacks: Overwhelming servers with traffic to disrupt services

SQL injection: Inserting malicious code into database queries

Cyberstalking: Harassment or threats via digital channels

2. BuildthemodelofaNetworkSecuritywithneatdiagram.



A Network Security Model explains how secure communication is achieved over an insecure network using security services, mechanisms, and protocols.
A security-related transformation on the information to be sent.
Examples include the encryption of the message, which scrambles the message so that it is unreadable by the opponent, and the addition of a code based on the contents of the message, which can be used to verify the identity of the sender.
Some secret information shared by the two principals and, it is hoped, unknown to the opponent.
An example is an encryption key used in conjunction with the transformation to scramble the message before transmission and unscramble it on reception.
A trusted third party may be needed to achieve secure transmission.
For example, a third party may be responsible for distributing the secret information to the two principals while keeping it from any opponent.

3. **Explainoperatingsystemvulnerabilitiesandthepossibleattacksassociatedwiththem.**

A vulnerability is a weakness or flaw in a computer system, network, application, or security process that can be exploited by an attacker to gain unauthorized access, steal data, disrupt services, or cause damage.

Operating Systems attacks, “attackers look for vulnerabilities in OS such that they can exploit through vulnerabilities and gain access to the target system or network”.

The vulnerabilities in the OS can be open ports and services as most of the operating systems install these services and ports by default. These are the most common vulnerabilities found by attackers to gain access to an operating system.

Some of the OS vulnerabilities list

- Buffer Overflow Vulnerability
- Bugs in the operating system
- Unpatched Operating System

Some of the attacks performed by OS Level

- Exploiting specific network protocol implementation
- Attacking built-in Authentication System
- Breaking file-system Security
- Cracking Passwords and Encryption Mechanism

Misconfiguration Attacks: Misconfiguration Attacks can be defined as “occurrence of errors while implementing all security controls”

It may occur either at any stage like developing, deploying, or maintaining, etc. Due to this attackers gain unauthorized access to the systems and affect web servers, databases, etc.

Prevention: Administrators need to change default configuration of the devices and deploy automated scanners.

Application-level Attacks: Defined as “A program or software which can perform a specific function to an end-user or for some other application”.

Since, the code for an application comes with more features and functionalities, there may be some undiscovered security holes or vulnerabilities leaving behind.

This is the opportunity for an attacker to find these vulnerabilities and exploit using different techniques to gain access and steal data.

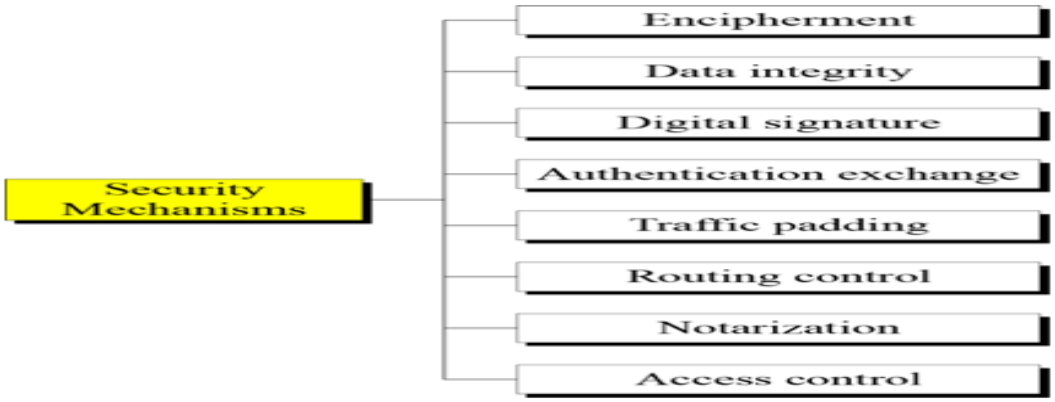
Prevention: these kind of attacks error checking or handling of applications must be strict.

Shrink-Wrap code Attacks:: It is defined as “exploiting the default configuration and settings of libraries and code”.

Prevention: have to fine-tune every part of the code and make it more secure.

4. **ExplainSecurityMechanismsinInformationandCyberSecurity.**

The security mechanisms defined in X.800. As can be seen the mechanisms are divided into those that are implemented in a specific protocol layer and those that are not specific to any particular protocol layer or security service.



Encipherment

The use of mathematical algorithms to transform data into a form that is not readily intelligible. The transformation and subsequent recovery of the data depend on an algorithm and zero or more encryption keys.

Data Integrity

A variety of mechanisms used to assure the integrity of a data unit or stream of data units

Authentication Exchange

A mechanism intended to ensure the identity of an entity by means of information exchange.

Digital Signatures

A digital signature or digital signature scheme is a mathematical scheme for demonstrating the authenticity of a digital message or document.

Traffic Padding

The insertion of bits into gaps in a data stream to prevent traffic analysis attempts.

Routing Control

Enables selection of particular physically secure routes for certain data and allows routing changes, especially when a breach of security is suspected.

Notarization

The use of a trusted third party to assure certain properties of a data exchange.

Access Control

A variety of mechanisms that enforce access rights to resources. Ex: pwd &pins

5. **ExplaintheroleofanIncidentResponseTeam.**

An incident response team is a group of IT professionals in charge of preparing for and reacting to any type of organizational emergency.

Responsibilities of an incident response team include developing a proactive incident response plan, testing for and resolving system vulnerabilities, maintaining strong security best practices and providing support for all incident handling measures.

Incident response team members typically cover various technical skills, backgrounds and roles to be prepared for a wide range of unforeseen security incidents.

In incident response, types of emergencies are usually categorized in two ways:

Public incidents. These incidents affect an entire community. This could include natural disasters, terrorist attacks and widespread epidemics.

Corporate/organizational incidents. These incidents are typically organization-specific and happen on a smaller scale. This could include data breaches, cybersecurity attacks and physical location threats.

Incident response teams are trained to be prepared for both types

Examples of incident response teams

Computer Security Incident Response Team (CSIRT). This is a team of professionals responsible for preventing and responding to security incidents.

Computer Emergency Response Team (CERT). This is a team of professionals in charge of handling cyberthreats and vulnerabilities within an organization.

Security Operations Center (SOC). This is a type of command center facility that is dedicated to monitoring, analyzing and protecting an organization from cyber attacks.

Incident response team functions and responsibilities::

Generally speaking, the core functions of an incident response team include leadership, investigation, communications, documentation and legal representation.

Leadership. Coordinates the overall direction and strategy of response activities and ensures the team stays

focused on minimizing damage, recovering quickly and operating efficiently.

Investigation. Coordinates efforts to determine an incident's root cause. It's important to gather as much relevant information as possible. Specifically, information that can provide value to correct the acute issue as well as prevent future issues.

Communications. Manages relevant internal and external communications necessary for the incident response. Communications may be required across an organization's teams and departments, or with external stakeholders.

Documentation. Keeps records of incident response measures and activities.

Legal representation. Ensures that the incident response activities taken line up with laws and regulations to protect the organization.

6. ExplainDigitalSignatureAlgorithmwithneatdiagram.

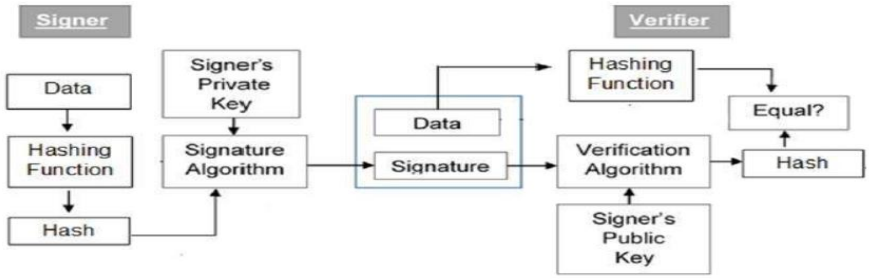
Digital signatures are the public-key primitives of message authentication. In the physical world, it is common to use handwritten signatures on handwritten or typed messages. They are used to bind signatory to the message.

Similarly, a digital signature is a technique that binds a person/entity to the digital data. This binding can be independently verified by receiver as well as any third party.

Digital signature is a cryptographic value that is calculated from the data and a secret key known only by the signer.

Model of Digital Signature

The digital signature scheme is based on public key cryptography. The model of digital signature scheme is depicted in the following illustration −



The following points explain the entire process in detail −

- Each person adopting this scheme has a public-private key pair.
- Generally, the key pairs used for encryption/decryption and signing/verifying are different. The private key used for signing is referred to as the signature key and the public key as the verification key.
- Signer feeds data to the hash function and generates hash of data.
- Hash value and signature key are then fed to the signature algorithm which produces the digital signature on given hash. Signature is appended to the data and then both are sent to the verifier.
- Verifier feeds the digital signature and the verification key into the verification algorithm. The verification algorithm gives some value as output.
- Verifier also runs same hash function on received data to generate hash value.
- For verification, this hash value and output of verification algorithm are compared. Based on the comparison result, verifier decides whether the digital signature is valid.
- Since digital signature is created by ‘private’ key of signer and no one else can have this key; the signer cannot repudiate signing the data in future.

7. **IllustratewithaneatdiagramthedifferentphasesinaSSLArchitecture.**

Secure Socket Layer (SSL) provides security to the data that is transferred between web browser and server.

SSL encrypts the link between a web server and a browser which ensures that all data passed between them remain private and free from attack.

The salient features of SSL protocol are as follows −

SSL provides network connection security through −

Confidentiality − Information is exchanged in an encrypted form.

Authentication − Communication entities identify each other through the use of digital certificates. Web-server authentication is mandatory whereas client authentication is kept optional.

Reliability − Maintains message integrity checks.

SSL is available for all TCP applications.

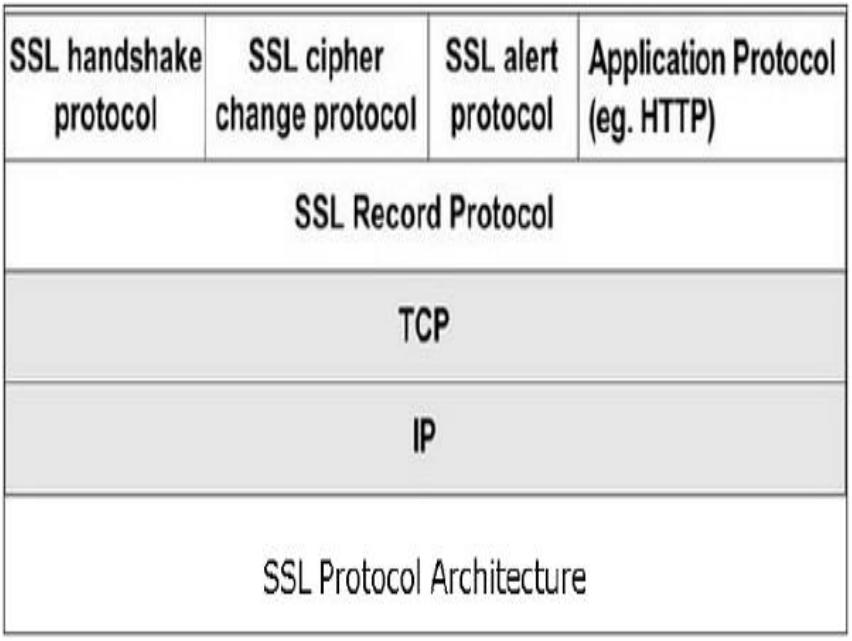
Supported by almost all web browsers.

Provides ease in doing business with new online entities.

Developed for Web e-commerce

Architecture of SSL

SSL protocol is designed to interwork between application and transport layer as shown in the following image −



The four sub-components of the SSL protocol handle various tasks for secure communication between the client machine and the server.

Record Protocol

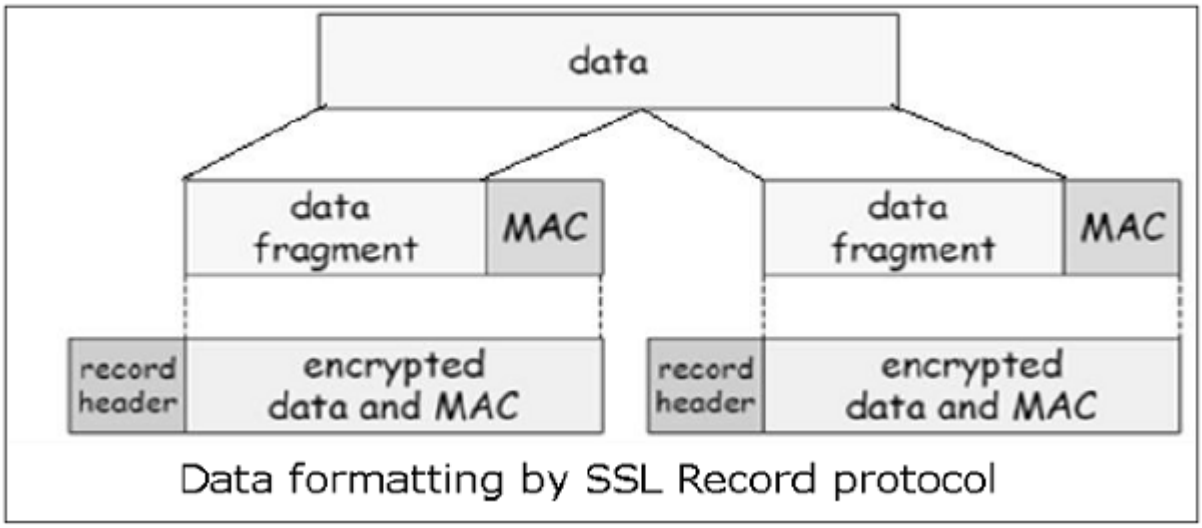
The record layer formats the upper layer protocol messages.

It fragments the data into manageable blocks (max length 16 KB). It optionally compresses the data.

Encrypts the data.

Provides a header for each message and a hash (Message Authentication Code (MAC)) at the end.

Hands over the formatted blocks to TCP layer for transmission.



SSL Handshake Protocol

It is the most complex part of SSL. It is invoked before any application data is transmitted.

It creates SSL sessions between the client and the server.

Establishment of session involves Server authentication, Key and algorithm negotiation, Establishing keys and Client authentication (optional).

A session is identified by unique set of cryptographic security parameters.

Multiple secure TCP connections between a client and a server can share the same session.

Handshake protocol actions through four phases.

ChangeCipherSpec Protocol

Simplest part of SSL protocol. It comprises of a single message exchanged between two communicating entities, the client and the server.

As each entity sends the ChangeCipherSpec message, it changes its side of the connection into the secure state as agreed upon.

The cipher parameters pending state is copied into the current state.

Exchange of this Message indicates all future data exchanges are encrypted and integrity is protected.

SSL Alert Protocol

This protocol is used to report errors – such as unexpected message, bad record MAC, security parameters negotiation failed, etc.

It is also used for other purposes – such as notify closure of the TCP connection, notify receipt of bad or unknown certificate, etc

8. ExplainIP Sec(IPSecurity)ProtocolswithneatDiagram.

The popular framework developed for ensuring security at network layer is Internet Protocol Security (IPsec).

Features of Ipsec

IPsec is not designed to work only with TCP as a transport protocol. It works with UDP as well as any other protocol above IP such as ICMP, OSPF etc.

IPsec protects the entire packet presented to IP layer including higher layer headers.

Since higher layer headers are hidden which carry port number, traffic analysis is more difficult.

IPsec works from one network entity to another network entity.

Tough widely used to provide secure communication between network entities, IPsec can provide host-to-host security as well.

The most common use of IPsec is to provide a Virtual Private Network (VPN), either between two locations (gateway-to-gateway) or between a remote user and an enterprise network (host-to-gateway).

The important security functions provided by the IPsec are as follows −

Confidentiality

Enables communicating nodes to encrypt messages.

Prevents eavesdropping by third parties.

Origin authentication and data integrity.

Provides assurance that a received packet was actually transmitted by the party identified as the source in the packet header.

Confirms that the packet has not been altered

Key management.

Allows secure exchange of keys.

Protection against certain types of security attacks, such as replay attacks.

The IPsec suite can be considered to have two separate operations providing a complete set of security services.

These two operations are IPsec Communication and Internet Key Exchange.

IPsec Communication

It is typically associated with standard IPsec functionality. It involves encapsulation, encryption, and hashing the IP datagrams and handling all packet processes.

Internet Key Exchange.

IKE is responsible for creation of keys for IPsec and providing authentication during key establishment process.

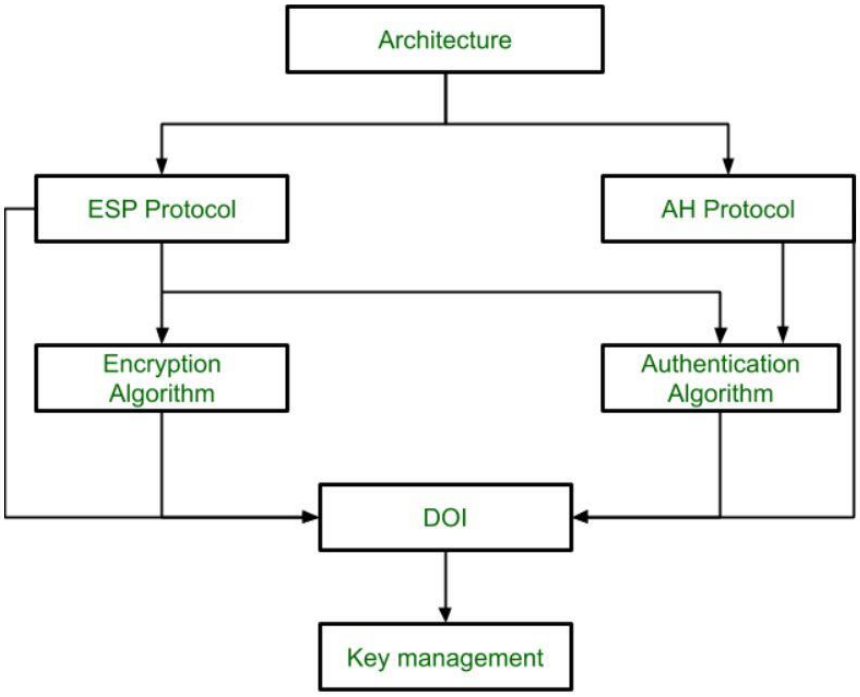
IPsec Communication has two modes of functioning

Transport mode

Transport mode encrypts only the payload (records) of the authentic IP packet, leaving the IP header intact. Its used for end-to-end communication between hosts.

Tunnel mode.

In tunnel mode, the complete original IP packet which includes the header and payload is encrypted and inserted into the brand-new IP packet. This mode is normally used for network-to-network connections.



IPsec uses the security protocols to provide desired security services.

Security associations between the communicating entities are established and maintained by the security protocol used.

There are two security protocols defined by IPsec — Authentication Header (AH) and Encapsulating Security Payload (ESP).

Authentication Header

The AH protocol provides service of data integrity and origin authentication. It optionally provides for message replay resistance. However, it does not provide any form of confidentiality.

Encapsulation Security Protocol (ESP)

ESP provides security services such as confidentiality, integrity, origin authentication, and optional replay resistance. The set of services provided depends on options selected at the time of Security Association (SA) establishment.

9. ExplaintheSHA-512algorithmindetail.

SHA-512, or Secure Hash method 512, is a hashing technique that converts text of arbitrary length into a fixed-size string. Each output has a SHA-512 length of 512 bits (64 bytes).

This algorithm is frequently used for email address hashing, password hashing, and digital record verification. SHA-512 is also used in blockchain technology, with the BitShares network becoming the most known example.

The SHA-512 algorithm consists of the following steps −

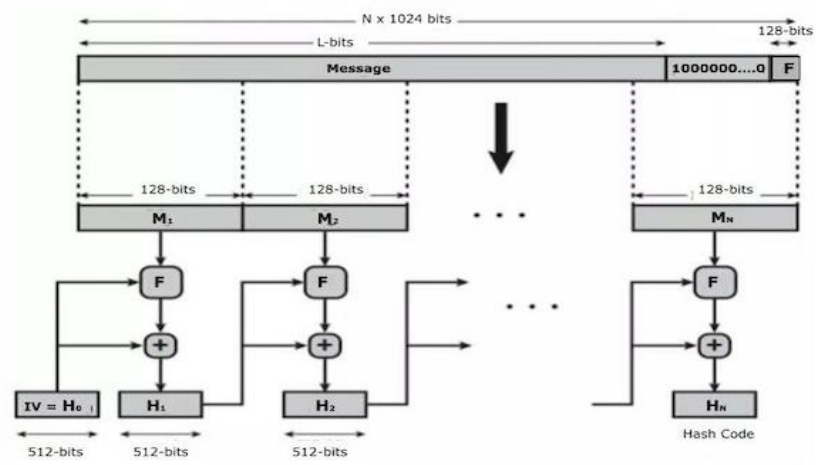
Message Padding − First, your message is padded to ensure that it is the correct size for the algorithm. This ensures that it can be broken down into blocks and processed.

Initial hash values − The algorithm starts with eight initial hash values. These set values serve as the basis for the hashing procedure.

Message processing − The padded message is divided into blocks. Each block progresses over a series of stages known as rounds. In each round, the block is mixed and adjusted using specific techniques.

Final hash value − After all blocks have been examined, the hash value is computed. This hash value serves as a unique fingerprint for the original message.

Output − The SHA-512 algorithm generates the final hash result, which is generally a string of hexadecimal integers. This is the value returned after hashing your original message.



10. **Outlinehowcybercriminalsplananattack?**

How Criminals plan the attack

• Criminals use many methods and tools to identify vulnerabilities of their target.

• Criminals plan attacks were categorised into – Active – Passive – Inside – Outside

• Active Attacks: – Def: To alter the system – Affects: Availability, Integrity and authenticity of data.

• Passive Attacks: – Def: To gain information about the target. – Affects: Confidentiality

• Inside Attack : – Def: Attempted within the security perimeter of an organisation. – Affects: Access more resources than expected.

• Outside attack: – Def: Attempted by a source outside the security perimeter (insider/outsider) who is indirectly associated with the organisation. – Sources: Either from internet or a remote access connection.

Phases to plan cyber crime

• Information gathering. (passive attack)

• Reconnaissance : To gain information about an enemy .

• Starts with Foot printing.

• Scanning and scrutinizing the information.

• For the validity of the information.

• To identify the existing vulnerabilities.

• Launching an attack

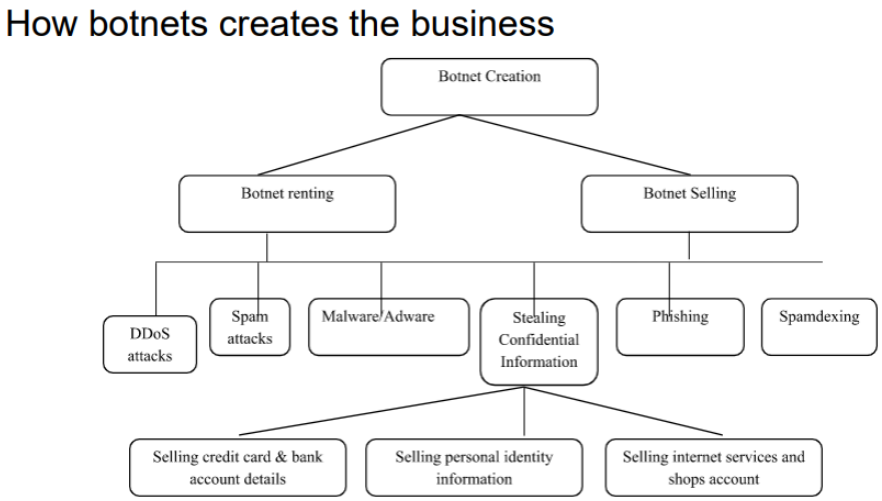
• Gaining and maintaining the system access.

11. Definecyberoffencesandcybercrime.DiscussindetailBotnetswithnecessarydiagram.

Botnet: The fuel of Cybercrime

- A Botnet (also called as zombie network) is a network of computers infected with a malicious program that allows cybercriminals to control the infected machines remotely without the users' knowledge.
- Your computer system maybe a part of a Botnet even though it appears to be operating normally.
- Botnets are often used to conduct a range of activities, from distributing Spam and viruses to conducting denial-of-service (DoS) attacks.

Evolution of Botnets • Motivation change in computer hacking – Vandalism – Financial gains



One can ensure following to secure the system:

1. Use antivirus and anti-Spyware software and keep it up-to-date.
2. Set the OS to download and install security patches automatically.
3. Use a firewall to protect the system from hacking attacks while it is connected on the Internet.
4. Disconnect from the Internet when you are away from your computer.
5. Downloading the freeware only from websites that are known and trustworthy
6. Check regularly the folders in the mail box – "sent items" or "outgoing" – for those messages you did not send.
7. Take an immediate action if your system is infected.